Finançat per la Unió Europea

IES MESTRE RAMON ESTEVE FP

GENERALITAT VALENCIANA
Conselleria d'Educació, Cultura, Universitats i Ocupació

UP3.4. MECANISMOS DE SEGURIDAD DEL SERVIDOR DE APLICACIONES

DESPLIEGUE DE APLICACIONES WEB

2º CFGS – DESARROLLO DE APLICACIONES WEB

RA3. Implanta aplicaciones web en servidores de aplicaciones, evaluando y aplicando criterios de configuración para su funcionamiento seguro.

PABLO PÉREZ GONZÁLEZ

CURSO 2025/26

INDEX

1. **MECANISMOS DE SEGURIDAD.**
   - INTRODUCCIÓN.
   - MECANISMOS COMUNES.
2. **SEGURIDAD EN EL SERVIDOR DE APLICACIONES.**
   - CONFIGURACIÓN.

RESULTADO DE APRENDIZAJE 3

CRITERIO DE EVALUACIÓN d)

RA3. Implanta aplicacions web en servidors d'aplicacions, avaluant i aplicant criteris de configuració per al seu funcionament segur.	
d) S'han configurat i activat els mecanismes de seguretat del servidor d'aplicacions.	15%

MECANISMOS DE SEGURIDAD

INTRODUCCIÓN

Un **servidor de aplicaciones** ejecuta y administra aplicaciones web y middleware (p. ej., Tomcat, JBoss, WebSphere). Dado que estos servidores gestionan datos críticos y tráfico web, necesitan contar con medidas de seguridad adecuadas para protegerse contra ataques, accesos no autorizados y vulnerabilidades.

MECANISMOS DE SEGURIDAD

MECANISMOS COMUNES

1. Autenticación:

- Autenticación básica: La identidad del usuario se verifica mediante credenciales como nombres de usuario y contraseñas.
- Autenticación mediante certificado: Los certificados digitales (SSL/TLS) se utilizan para verificar la identidad del servidor o cliente. Esta es una de las formas de autenticación más seguras.

2. Autorización: Una vez autenticado un usuario, la autorización controla los recursos a los que puede acceder. Esto puede incluir el control de acceso basado en roles (RBAC), donde los permisos de acceso se otorgan según el rol del usuario (por ejemplo, administrador, usuario normal, etc.).

3. Cifrado de comunicaciones (SSL/TLS): Proteger las comunicaciones entre el servidor y los clientes es crucial. El cifrado SSL/TLS garantiza que los datos transmitidos entre el navegador del usuario y el servidor web estén cifrados, lo que protege contra ataques de intermediario o intercepciones.

MECANISMOS DE SEGURIDAD

MECANISMOS COMUNES

4. Configuración del firewall de aplicaciones web (WAF): Implementar un firewall de aplicaciones web (WAF) permite filtrar, supervisar y bloquear el tráfico HTTP que entra y sale del servidor de aplicaciones. Los WAF están diseñados para proteger contra ataques comunes como inyecciones SQL, secuencias de comandos entre sitios (XSS) y falsificación de solicitudes entre sitios (CSRF).

5. Reglas de acceso y políticas de seguridad: Establezca políticas de seguridad que determinen quién puede acceder a qué partes de la aplicación. Esto incluye la configuración de firewalls, listas blancas/negras de IP y la restricción del acceso a ciertos directorios o servicios.

6. Gestión segura de sesiones: Las aplicaciones deben gestionar las sesiones de forma segura, garantizando que los identificadores de sesión sean únicos y difíciles de adivinar. Las sesiones deben tener tiempos de expiración y, si es posible, las cookies de sesión deben marcarse como seguras y accesibles solo a través de HTTPS.

7. Protección contra ataques de fuerza bruta y denegación de servicio (DoS/DDoS): Configure el servidor para limitar el número de intentos fallidos de inicio de sesión y otras prácticas de mitigación de ataques de fuerza bruta. Los mecanismos de protección contra DDoS pueden incluir la limitación de velocidad y el bloqueo de IP que realizan solicitudes sospechosas.

1. Configuración de autenticación y autorización.

La autenticación y la autorización se pueden configurar tanto a nivel de servidor de aplicaciones como de aplicación web. En servidores como Tomcat o JBoss, los roles y las restricciones suelen definirse en archivos de configuración XML o mediante archivos de implementación específicos como `web.xml`.

En Tomcat, se pueden definir reglas de acceso en el archivo **`tomcat-users.xml`** y configurar roles de usuario para acceder a diferentes partes de la aplicación.

2. Configuración de certificados digitales (SSL/TLS).

Configurar un certificado SSL/TLS implica instalar y configurar certificados en el servidor de aplicaciones. El tráfico entre el cliente y el servidor de aplicaciones estará cifrado y protegido. En Tomcat, esto se realiza configurando el conector SSL en el archivo **`server.xml`** y especificando el puerto, el protocolo y la ubicación del certificado.

```
<Connector port="8443" protocol="org.apache.coyote.http11.Http11NioProtocol"
           maxThreads="150" SSLEnabled="true">
    <SSLHostConfig>
        <Certificate certificateKeystoreFile="conf/localhost-rsa.jks"
                     type="RSA" />
    </SSLHostConfig>
</Connector>
```

3. Configuración de restricciones de acceso IP.

Además de la autenticación basada en usuarios, puede restringir el acceso al servidor según la IP desde la que se realiza la conexión. En Tomcat, por ejemplo, esto se puede hacer configurando el conector en el archivo **`server.xml`** o usando reglas de seguridad en el firewall del servidor.

4. Configuración de un WAF (firewall de aplicaciones web).

Un firewall de aplicaciones web actúa como un filtro para las solicitudes HTTP, bloqueando los intentos de ataque antes de que lleguen a la aplicación. Puede instalar un WAF externo o configurar las reglas del firewall directamente en el servidor de aplicaciones.

5. Cifrado y gestión segura de contraseñas.

Las contraseñas utilizadas en las aplicaciones deben estar cifradas, tanto en la base de datos como en los archivos de configuración. En muchos servidores de aplicaciones, es posible usar JDBC Realms para gestionar la autenticación y cifrar las contraseñas en la base de datos de usuarios.

PREGUNTAS

DUDAS Y SUGERENCIAS